

VAPT and SEO Assessment

Product: Consent Guru (consent-manager) · Target: consentguru.com · Date: 19 September 2026
Method: static source-code review (Next.js App Router, Clerk, Drizzle/Postgres). No live exploit, payload, or attack procedure.

78 / 100

VAPT score · rating B

72 / 100

SEO score · rating C+

1

Critical finding

3

High findings

How to read these scores

This is not a live pentest against a production URL. Findings are from repository review. Do not treat 78 as a substitute for an authorized external pen test after Clerk, HMAC, and webhook secrets are set. Diff-based change review had an empty tree, so this is a full-app baseline.

1. Executive summary

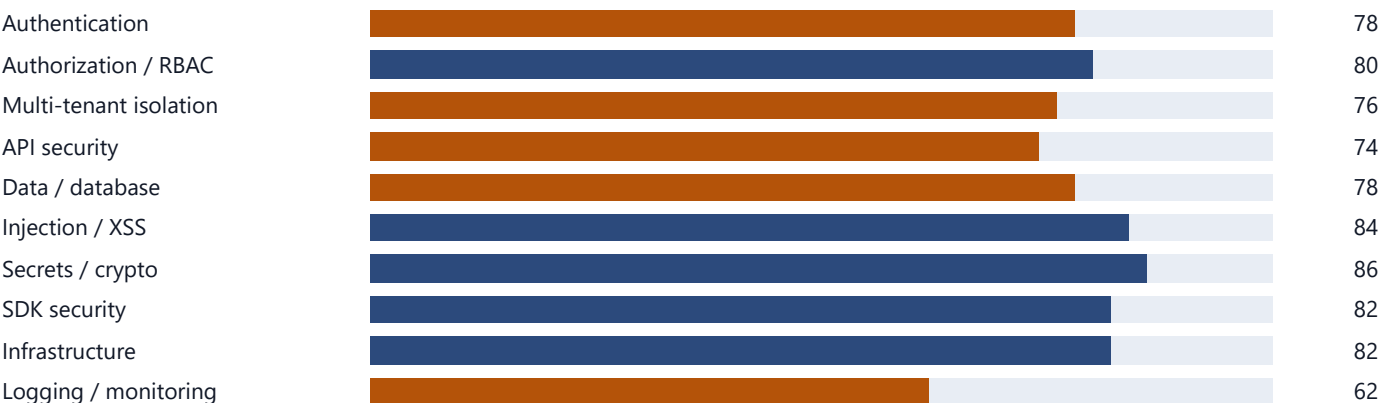
Consent Guru has a solid security baseline: Clerk `auth.protect()` with a public allowlist, CSRF origin checks on dashboard APIs, security headers plus Clerk CSP, SSRF guards, parameterized SQL, and operator gates on API keys, webhooks, and policy publish.

The VAPT score is held at 78 by fail-open auth when Clerk is unset, process-local rate limits, Member-level config writes, DSAR tokens in JSON responses, and no Postgres RLS.

SEO is held at 72 by missing `robots.ts` / `sitemap.ts` and indexable dashboard/auth pages. Marketing metadata, Open Graph, and 31 blog posts are already strong.

2. VAPT score model

Each category is scored 0–100. Overall is the weighted sum, rounded to a whole number.



Source: static review of `src/proxy.ts`, API routes, SDK public HTTP, and security headers · 19 Sep 2026.

Category	Score	Weight	Weighted
Authentication & sessions	78	10%	7.80
Overall VAPT	78 / 100	100%	78.36

Category	Score	Weight	Weighted
Authorization / RBAC	80	15%	12.00
Multi-tenant isolation	76	15%	11.40
API security	74	12%	8.88
Data / database	78	10%	7.80
Injection / XSS	84	10%	8.40
Secrets / cryptography	86	8%	6.88
SDK security	82	8%	6.56
Infrastructure / configuration	82	6%	4.92
Logging / monitoring	62	6%	3.72
Overall VAPT	78 / 100	100%	78.36

Internal `SECURITY_SCORE.md` (11 Sep 2026) rated 8.5 / 10 after P0/P1 remediations. This VAPT score is stricter: it includes fail-open Clerk, DSAR token return, and Member mutations.

3. VAPT findings

Finding counts: 1 Critical · 3 High · 8 Medium · 6 Low / informational (18 total). Table below lists the primary items used in scoring.

ID	Severity	Finding	Location
S-C1	Critical	If Clerk keys are unset, the proxy skips <code>auth.protect()</code> and still serves the app.	<code>src/proxy.ts:97-108</code>
S-H1	High	Rate limits are process-local Maps and will not hold across serverless isolates.	<code>src/lib/rate-limit.ts:18-65</code>
S-H2	High	Public SDK config GET has Origin checks and ETag cache, but no rate limit.	<code>src/app/api/sdk/[siteKey]/config/route.ts</code>
S-H3	High	<code>siteKey</code> is a long-lived public capability token with CORS <code>*</code> .	<code>src/lib/sdk/public-http.ts</code>
S-M1	Medium	Many CRUD APIs allow any active Member (no <code>requireOperatorRole</code>).	<code>src/app/api/purposes/route.ts:75-81</code>
S-M2	Medium	Consent policy public GET is <code>websiteId</code> + Origin only — no <code>siteKey</code> .	<code>src/app/api/consent/policy/route.ts:19-51</code>
S-M3	Medium	Domain verified flag is unused when allowing SDK Origin.	<code>src/lib/sdk/origin-allowlist.ts:62-65</code>
S-M4	Medium	Widespread <code>console.error</code> of raw errors (stacks / incidental PII in log drains).	<code>src/app/api/**</code>
S-M5	Medium	CSRF treats <code>Sec-Fetch-Site: none</code> as trusted.	<code>src/lib/security-headers.ts:118-120</code>

ID	Severity	Finding	Location
S-M6	Medium	No Postgres RLS — tenant isolation is application queries only.	Drizzle / schema
S-M7	Medium	Public DSAR intake returns plaintext verification and status tokens in JSON.	src/app/api/rights-request/route.ts:99-100
S-M8	Medium	SDK config exposes org DPO / grievance emails (often legally required on notices).	src/app/api/sdk/[siteKey]/config/route.ts
S-L1	Low	Unauthenticated /api/health reports database health.	src/app/api/health/route.ts:9-15
S-L2	Low	CSP frame-src allows any https origin (banner studio previews).	src/lib/security-headers.ts:52-53
S-I1	Info	Session cookie flags are Clerk-managed. Confirm MFA in the Clerk Dashboard.	Clerk configuration

Remediation (priority order)

1. Fail closed in production when Clerk is not configured (refuse start or 503). Never skip `auth.protect` for dashboard and private APIs.
2. Move rate-limit buckets to Redis/Upstash keyed by IP + siteKey/org. Add a limiter on SDK config GET.
3. Restrict purpose/website/vendor mutations to Owner/Admin. Keep Members read-only unless the product requires otherwise.
4. Require siteKey on `/api/consent/policy`. Treat `websiteId` as insufficient.
5. Do not return DSAR `verificationToken` / `statusToken` in the JSON body; deliver via email and return an opaque reference.
6. Add Postgres RLS on `organization_id`. Route errors through `logger.error` only.

What is already strong

Auth and CSRF. Public route matcher plus `auth.protect()`. Dashboard state-changing APIs origin-checked. Bearer API keys scoped (`consent:evaluate`). Cron/webhooks use timing-safe secret compare when configured.

Headers and CSP. `nosniff`, `Referrer-Policy`, `X-Frame-Options`, `Permissions-Policy`, `COOP`, `HSTS` in production. Clerk CSP strict plus extra directives.

SSRF and input. Scanner, webhooks, and domain verify go through `ssrf-guard`. Public JSON size limits and siteKey regex. Banner URL/CSS sanitization.

Data access. Drizzle bound parameters. High-risk ops (API keys, webhooks, policy publish) use `requireOperatorRole`. Evidence reads are org-scoped.

4. SEO score model

Weighted: Technical 30% · On-page 20% · Content 20% · Performance 15% · Social 15%.

Technical		55
On-page		78
Content		82
Performance		72
Social		80

Category	Score	Weight	Weighted
Technical	55	30%	16.50
On-page	78	20%	15.60
Content	82	20%	16.40
Performance	72	15%	10.80
Social	80	15%	12.00
Overall SEO	72 / 100	100%	71.80

Highest-ROI SEO gaps

No robots.ts or sitemap.ts. Dashboard, sign-in, and sign-up inherit indexable root metadata. About is missing a canonical. Utility pages (sdk-demo, privacy-request, guardian-consent) have no page-level metadata.

5. SEO checklist

Area	Status	Where
Root title, description, keywords, metadataBase	Present	src/app/layout.tsx:29-62
Open Graph + Twitter large image	Present	src/lib/site-metadata.ts:20-65
Canonical on home, blogs, posts, e-learning	Present	layout, blogs, e-learning pages
SoftwareApplication JSON-LD	Present	src/app/layout.tsx:81-96
31 blog posts with article OG publishedTime	Present	src/content/blogs.ts
robots.txt / robots.ts	Missing	not in repo
sitemap.xml / sitemap.ts	Missing	not in repo
Dashboard robots noindex	Missing	src/app/dashboard/layout.tsx
About canonical	Missing	src/app/about/page.tsx:10-19
BlogPosting JSON-LD	Missing	src/app/blogs/[slug]/page.tsx
privacy-request / sdk-demo metadata	Missing	client pages inherit root title
Blog covers via next/image	Partial	blog-cover.tsx uses raw img
hreflang / i18n routes	None	html lang=en vs OG locale en_IN

Index vs noindex

Surface	Today	Should be
/, /about, /blogs/*, /e-learning	Indexable	Index — add to sitemap

Surface	Today	Should be
/dashboard/**	No robots override	noindex, nofollow
/sign-in, /sign-up, /create-organization	Inherits root	noindex, nofollow
/sdk-demo, /privacy-request, /guardian-consent	Inherits root	noindex (unless DSAR SEO is intended)
public/e2e-customer-*.html	Crawlable static files	Disallow in robots or omit from production

Highest-ROI SEO fixes

- 1. Add `src/app/robots.ts` and `src/app/sitemap.ts` (home, about, e-learning, blogs from `getAllBlogs()`).
- 2. Set `robots: { index: false }` on dashboard and auth layouts.
- 3. Add `alternates.canonical` on /about; unique metadata on utility pages.
- 4. Emit BlogPosting JSON-LD on blog posts.
- 5. Switch BlogCover to `next/image` with sizes.

Closing robots, sitemap, and noindex on app routes would likely lift Technical into the 80s and overall SEO into the high 70s without new content.

6. Out of scope

Live network scanning, dependency CVE dump, Clerk Dashboard MFA verification, and production header observation. Those need a deployed environment with secrets configured.